

A.H

PROCEDIMIENTO DE CUMPLIMIENTO Política de Seguridad de ACME, S.A.U.

INTRODUCCIÓN

Este documento describe los procedimientos de auditoría necesarios para verificar el cumplimiento de la política de seguridad establecida por ACME, S.A.U. Se detallan los controles, técnicas y evidencias requeridas para cada punto de la política.

1. AUTENTICACIÓN CON CREDENCIALES ÚNICAS

Política: Todos los usuarios deben autenticarse con credenciales únicas. No se permiten usuarios genéricos.

1.1. Objetivo del control

Garantizar que cada persona que accede a los sistemas de la empresa tenga sus propias credenciales, para poder identificar de forma inequívoca quién realiza cada acción y poder hacer un seguimiento individual de las actividades. Esto ayuda también a establecer responsabilidades claras.

1.2. Qué se comprueba (criterio de auditoría)

- Que no existan cuentas compartidas entre varios empleados
- Que cada empleado tenga asignado un usuario único y personal
- Que no haya usuarios genéricos tipo "admin", "usuario", "invitado" o "compartido" activos en el sistema
- Que los nombres de usuario permitan identificar al titular de la cuenta

1.3. Cómo se comprueba (técnica de auditoría)

- Extraer un listado completo de usuarios del sistema (Active Directory, base de datos de usuarios, etc.)
- Comparar el listado de usuarios con el listado de empleados activos de RRHH
- Entrevistar al responsable de TI sobre el proceso de alta y baja de usuarios
- Revisar los registros de creación de cuentas de los últimos 6 meses
- Buscar en el sistema usuarios con nombres genéricos o sospechosos de ser compartidos

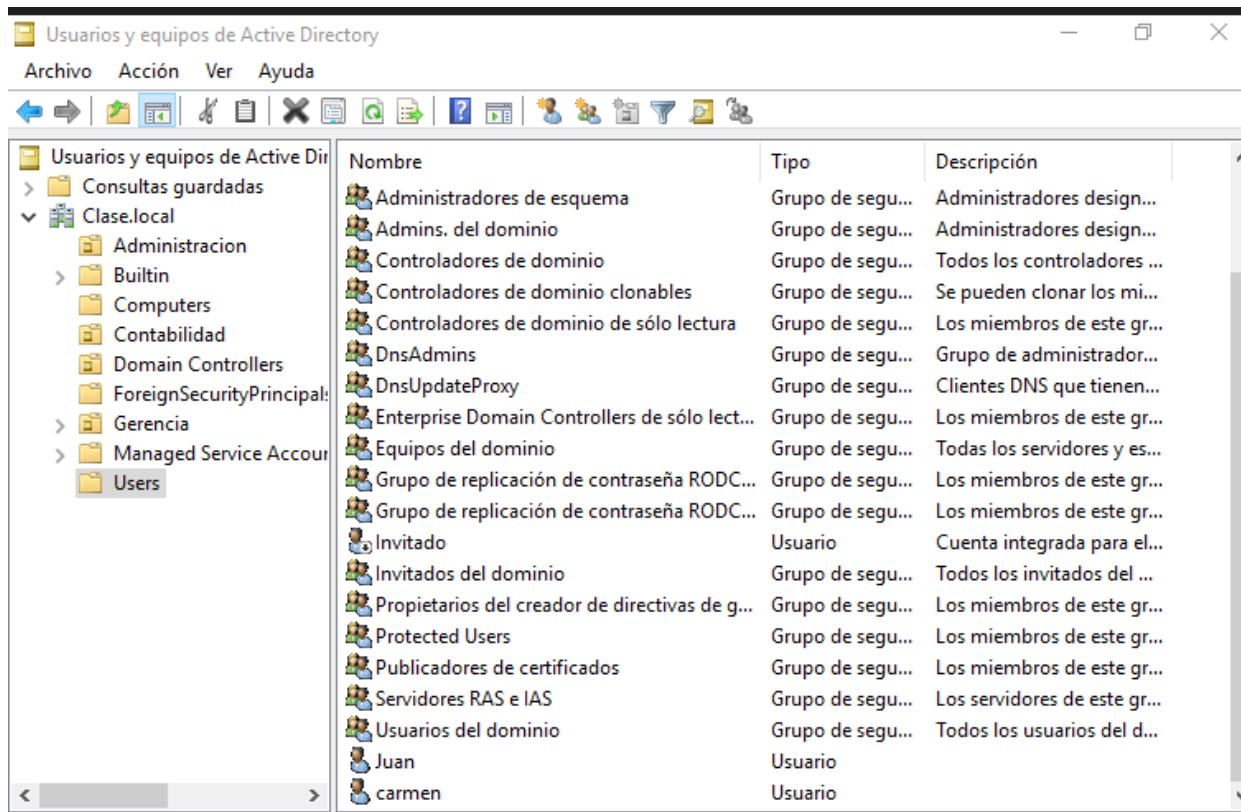
1.4. Evidencias necesarias

- Listado exportado de todos los usuarios del sistema (captura de pantalla o export en CSV/Excel)
- Plantilla actualizada de empleados proporcionada por RRHH
- Documento de política de creación de usuarios
- Logs o registros de alta/baja de usuarios (al menos últimos 3 meses)
- Acta de entrevista con el responsable de TI

1.5. Resultado esperado

CUMPLE: Si todos los usuarios pueden vincularse a una persona física concreta y no existen usuarios genéricos o compartidos.

NO CUMPLE: Si se detectan usuarios genéricos activos, usuarios compartidos entre varias personas, o usuarios sin titular identificado.



Captura mostrando usuarios únicos e identificados.

2. RENOVACIÓN DE CONTRASEÑAS CADA 90 DÍAS

Política: Las contraseñas deben renovarse cada 90 días.

2.1. Objetivo del control

Reducir el riesgo de que contraseñas comprometidas o descubiertas puedan ser utilizadas durante mucho tiempo. La renovación periódica limita la ventana de oportunidad para un atacante y fomenta que los usuarios mantengan contraseñas actualizadas.

2.2. Qué se comprueba (criterio de auditoría)

- Que exista una política técnica configurada en el sistema que fuerce el cambio cada 90 días
- Que los usuarios realmente estén cambiando sus contraseñas dentro del plazo establecido
- Que no existan excepciones o cuentas que no cumplan este requisito
- Que el sistema avise a los usuarios antes del vencimiento

2.3. Cómo se comprueba (técnica de auditoría)

- Revisar la configuración de políticas de contraseñas en el sistema (GPO en Windows, /etc/login.defs en Linux, etc.)
- Consultar la fecha del último cambio de contraseña de una muestra de usuarios (mínimo 10-15 usuarios aleatorios)
- Verificar si el sistema está notificando a los usuarios próximos al vencimiento
- Comprobar que no hay cuentas de servicio o administradores exentos sin justificación documentada

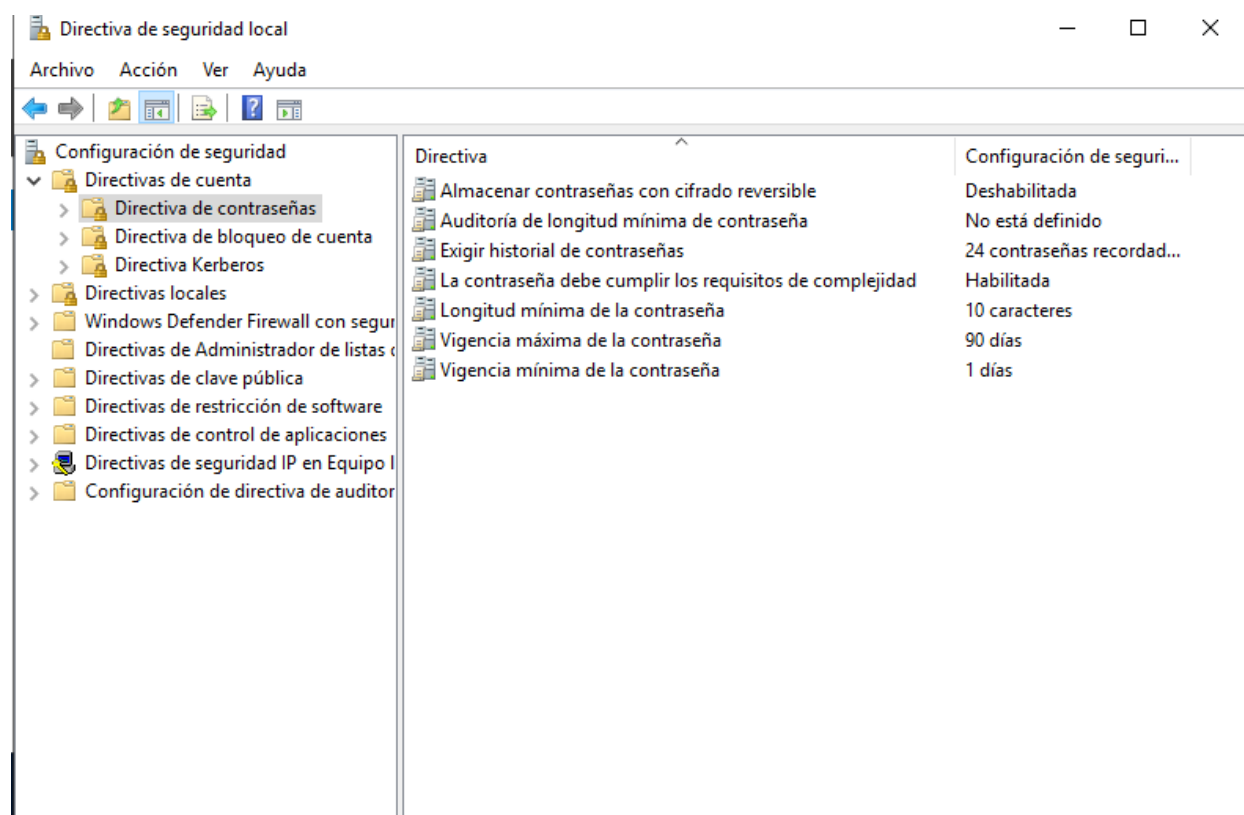
1.4. Evidencias necesarias

- Captura de pantalla de la política de contraseñas configurada en el sistema
- Reporte con las fechas de último cambio de contraseña de los usuarios auditados
- Ejemplo de notificación de vencimiento que reciben los usuarios
- Documento que justifique excepciones si las hubiera (por ejemplo, cuentas de servicio)

2.5. Resultado esperado

CUMPLE: Si la política de 90 días está configurada y activa, y la muestra de usuarios auditados ha cambiado su contraseña dentro del plazo.

NO CUMPLE: Si la política no está configurada, está deshabilitada, o se encuentran usuarios con contraseñas de más de 90 días sin cambiar.



Vigencia de 90 días.

3. COMPLEJIDAD DE CONTRASEÑAS

Política: Las contraseñas deben cumplir: mínimo 1 carácter especial, 1 mayúscula, 1 minúscula, 1 dígito y 10 caracteres de longitud mínima.

3.1. Objetivo del control

Asegurar que las contraseñas sean lo suficientemente robustas como para resistir ataques de fuerza bruta o diccionario. La complejidad dificulta que un atacante pueda adivinar o descifrar la contraseña fácilmente.

3.2. Qué se comprueba (criterio de auditoría)

- Que el sistema tenga configurada la política de complejidad especificada
- Que sea técnicamente imposible crear una contraseña que no cumpla los requisitos
- Que todos los usuarios tengan contraseñas que cumplan con estos criterios (mediante prueba de creación)

3.3. Cómo se comprueba (técnica de auditoría)

- Revisar la configuración de complejidad de contraseñas en el sistema (GPO, PAM, configuración de aplicación)
- Realizar una prueba práctica intentando crear o cambiar una contraseña que NO cumpla los requisitos (debería ser rechazada por el sistema)
- Verificar que el sistema muestra un mensaje claro explicando los requisitos cuando se crea/cambia contraseña
- Consultar al administrador cómo se validó esta configuración inicialmente

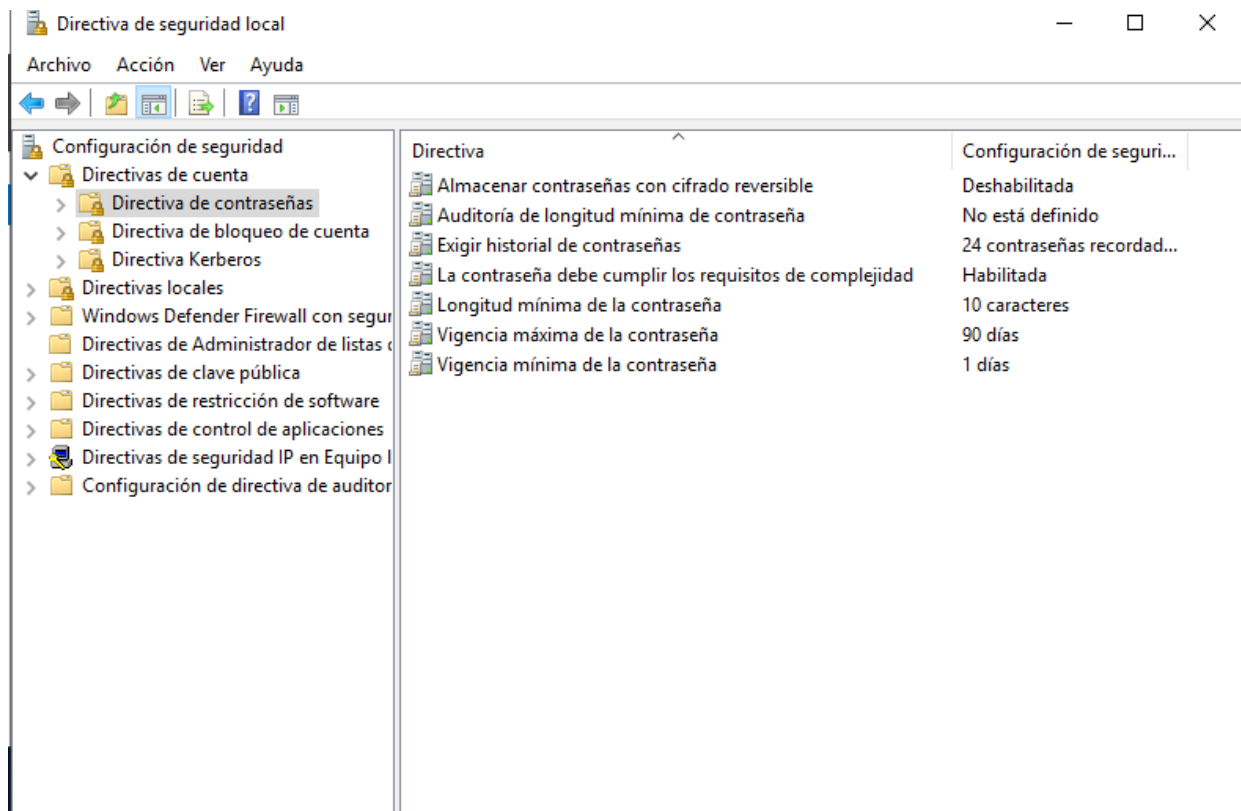
3.4. Evidencias necesarias

- Captura de pantalla de la configuración de complejidad de contraseñas
- Registro de la prueba práctica realizada (capturas mostrando el rechazo de contraseñas débiles)
- Mensaje de error o ayuda que muestra el sistema con los requisitos
- Documento de política de contraseñas de la empresa

3.5. Resultado esperado

CUMPLE: Si la política está configurada correctamente con todos los requisitos y las pruebas confirman que el sistema rechaza contraseñas que no cumplen.

NO CUMPLE: Si la configuración no refleja todos los requisitos, si permite crear contraseñas débiles, o si la longitud mínima es inferior a 10 caracteres.



La contraseña debe cumplir los requisitos de complejidad: habilitada.

4. COPIAS DE SEGURIDAD

Política: Se deben realizar copias de seguridad completas semanalmente y copias parciales (incrementales/diferenciales) diariamente.

4.1. Objetivo del control

Garantizar la disponibilidad y recuperación de la información crítica en caso de fallo del sistema, borrado accidental, ciberataque (como ransomware) o desastre. Las copias frecuentes minimizan la pérdida de datos.

4.2. Qué se comprueba (criterio de auditoría)

- Que exista una planificación documentada de las copias de seguridad
- Que se estén ejecutando copias completas cada semana
- Que se estén ejecutando copias parciales todos los días laborables
- Que las copias se completen correctamente sin errores
- Que se hayan realizado pruebas de restauración recientemente (últimos 6 meses mínimo)

4.3. Cómo se comprueba (técnica de auditoría)

- Revisar el software de backup y su configuración (Veeam, Acronis, Windows Backup, etc.)
- Consultar los logs de backup de las últimas 4 semanas para verificar la ejecución
- Comprobar que las copias completas aparecen cada 7 días y las parciales diariamente
- Verificar el estado de las últimas copias (exitosas, con errores, etc.)
- Solicitar evidencia de la última prueba de restauración realizada

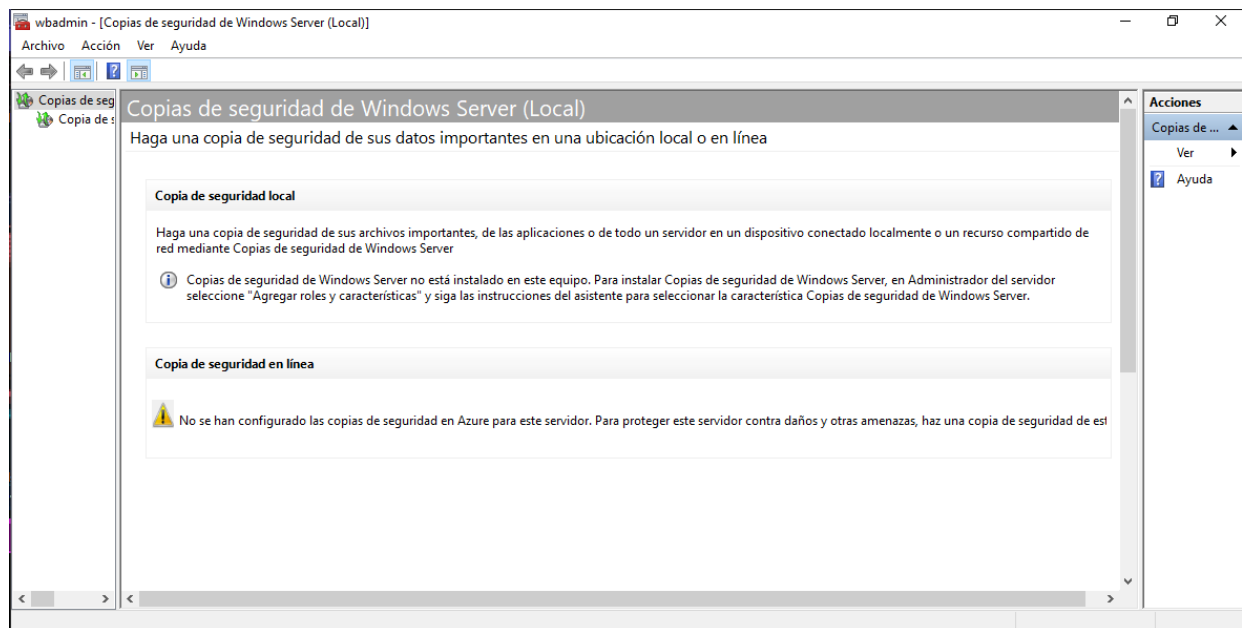
4.4. Evidencias necesarias

- Documento de planificación o calendario de backups
- Capturas de pantalla del software de copias de seguridad con la configuración actual
- Logs o reportes de las últimas 4 semanas mostrando las ejecuciones
- Registro de la última prueba de restauración (acta, screenshots, informe)
- Entrevista o correo del responsable de sistemas explicando el proceso

4.5. Resultado esperado

CUMPLE: Si se confirma que las copias completas se ejecutan semanalmente, las parciales diariamente, todas finalizan correctamente, y existe evidencia de pruebas de restauración en los últimos 6 meses.

NO CUMPLE: Si no existe planificación formal, si las copias no se ejecutan con la frecuencia requerida, si hay fallos frecuentes sin resolver, o si no se han probado las restauraciones.



Programa de copias de seguridad de Windows.

CONCLUSIÓN

Este procedimiento de cumplimiento establece las bases para verificar si ACME, S.A.U. cumple con su política de seguridad. Cada control debe revisarse de forma sistemática, recogiendo las evidencias indicadas. Al final de la auditoría, se elaborará un informe consolidado con los hallazgos y recomendaciones de mejora necesarias.